

AI Threat Navigator

Context-based threat modelling guide for AI solutions

Choose the type of AI, then follow the feature and configuration questions to the risks that apply.
Risks map behind the scenes to OWASP LLM Top 10 (2025) and the Agentic Top 10 (ASI, 2026).

Start here

Start with the baseline questions, then pick the type of AI you are assessing and work its feature and configuration questions. AI governance is a prerequisite and baseline cyber a related activity, both owned by your existing governance processes.

Prerequisites and related activities

AI governance (registration, risk profiling, Review Panel, sign-off) is a prerequisite. This navigator extends the baseline cyber threat identification in STRIDE, the standard method. DREAD ranks risk rather than identifying it.

[Baseline questions](#)

[Third-party AI](#)

[Someone else's AI feature or product](#)

[Open](#)

[Low-code](#)

Copilot Studio or Power Platform

[Open](#)

[API integration / GenAI app](#)

Custom application on a model API

[Open](#)

[Agentic app](#)

Tools, planning, memory, autonomy

[Open](#)

[Code generation](#)

Developer assistant, Claude Code

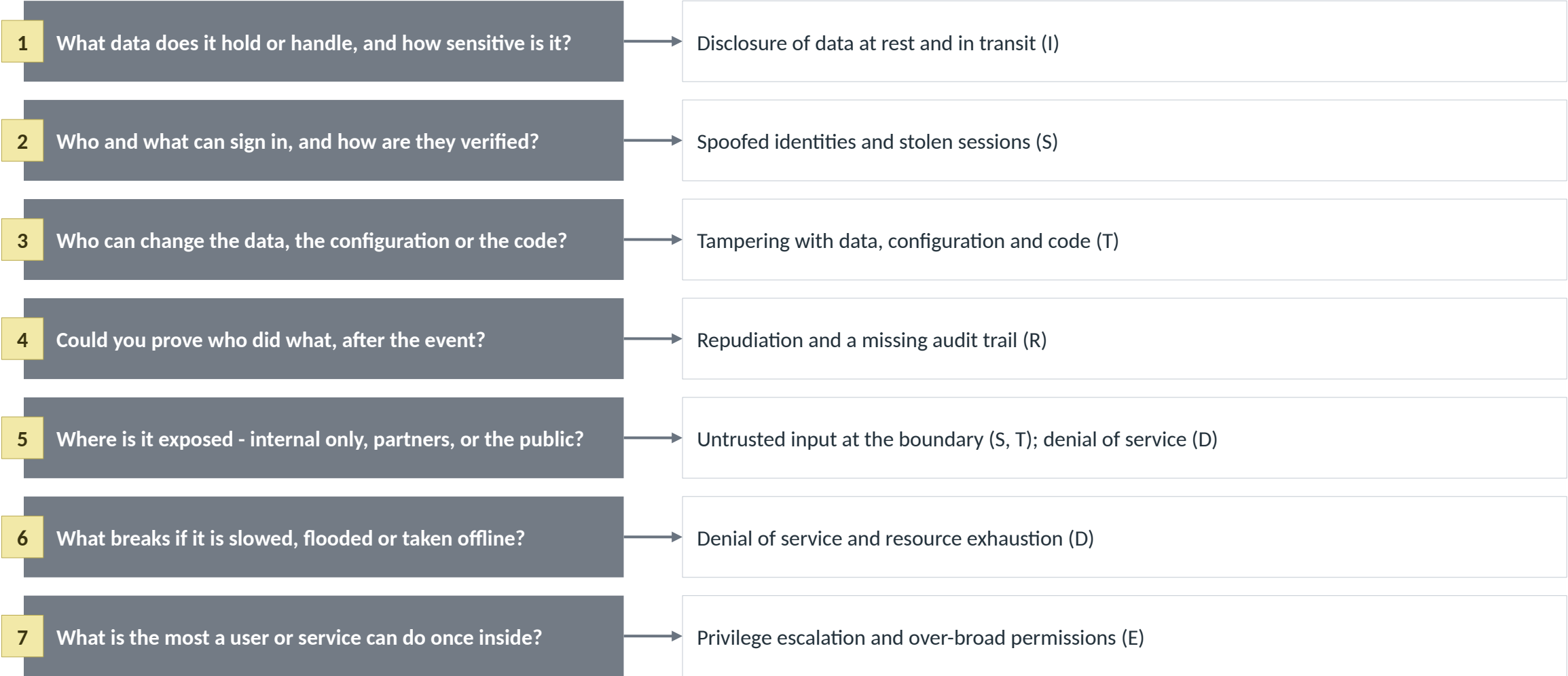
[Open](#)

Risks link through to the mitigations for that type. Record each answer and the risks that apply: the marked-up set is the threat model you take to review. Reference: [Threat groups](#) · [ATLAS \(LLM\)](#) · [ATLAS \(Agentic\)](#) · [Frameworks](#)

Baseline questions

Plain cyber questions, asked of any solution before the type is chosen. The answers draw the system boundary and give the STRIDE findings the AI-specific questions build on.

STRIDE: Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege.



Continue to the type-specific questions

Third-party AI (1 of 2)

Consumed / embedded (someone else's AI feature or product)

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance <i>Prerequisite</i>	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber <i>Related activity</i>	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions >
1	Handles sensitive or personal data?	Data exposure (LLM02) Residency and sovereignty (Gov) Test against: T0024.000/.001/.002, T0057, T0025, T0048.004	
2	Unmanaged or personal-account use?	Shadow AI (Gov) Uncontrolled leakage (LLM02) Test against: T0012, T0036, T0037	
3	Vendor trains on your data or prompts?	IP and data exposure (LLM02) Retention / opt-out (Gov) Test against: T0024.002, T0048.004, T0057	

Third-party AI (2 of 2)

Consumed / embedded (someone else's AI feature or product)

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance <i>Prerequisite</i>	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber <i>Related activity</i>	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions >
4 You add your own data (RAG, connectors)?		Hidden prompt injection (LLM01) Over-broad access (LLM06) Test against: T0066, T0070, T0071, T0085.000	
5 Can it take actions, read-only or consequential?		Excessive agency (LLM06) See the Agentic or Code generation navigator Test against: T0053, T0086, T0101	
6 Always: third-party assurance		Supply-chain and model-change risk (LLM03) Overreliance on outputs (LLM09) Test against: T0010.000-.005, T0109, T0111, T0115.000/.001/.002	

Low-code (1 of 2)

Copilot Studio / Power Platform or other low-code environments (Salesforce, Workday, other)

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance <i>Prerequisite</i>	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber <i>Related activity</i>	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions ›
1 Built in the default environment?		Unrestricted authoring (Gov) No DLP, sprawl (Gov) Test against: T0103, T0081, T0002.002	
2 Wired to knowledge sources (SharePoint, MCP)?		Over-broad access (LLM06) Hidden injection, DLP gaps (LLM01) Test against: T0064, T0066, T0070, T0071, T0085.000	
3 Connectors or Power Automate: read-only or consequential?		Tool misuse (ASI02, LLM06) Tenant-isolation bypass, exfiltration (Baseline) Test against: T0053, T0086, T0101, T0110.000/.002	

Low-code (2 of 2)

Copilot Studio / Power Platform or other low-code environments (Salesforce, Workday, other)

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance <i>Prerequisite</i>	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber <i>Related activity</i>	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions ›
4 Own agent identity, or inherits maker rights?		Identity and privilege abuse (ASIO3, LLM06) No audit trail (Gov) Test against: T0012, T0055, T0083, T0091.000/.001	
5 Published to Teams or the web?		Untrusted-user injection (ASIO1, LLM01) Exposure (LLM02) Test against: T0093, T0051.001, T0052.000	
6 Autonomous flows, or multi-agent?		Excessive agency, cascading actions (ASIO8, LLM06) Rogue agents (ASIO10, LLM09) Test against: T0108, T0103, T0034.002, T0029 - ASIO7 and ASIO8 analogues only	

API integration / GenAI app (1 of 2)

Custom application on a model API

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance Prerequisite	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber Related activity	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions
1 Takes untrusted user input?		Prompt injection (LLM01) Jailbreak (LLM01) Test against: T0051.000, T0054, T0068, T0093	
2 Uses RAG or a vector store?		Poisoned index, hidden injection (LLM01, LLM08) Sensitive data in embeddings (LLM08, LLM02) Test against: T0064, T0066, T0070, T0071, T0082, T0085.000	
3 System prompt holds logic or secrets?		System-prompt and secrets leakage (LLM07) Test against: T0056, T0069.000/.001/.002, T0084.000	

API integration / GenAI app (2 of 2)

Custom application on a model API

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance Prerequisite	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber Related activity	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions ›
4	Output rendered, run or stored downstream?	Improper output handling (LLM05) Downstream injection (LLM05) Test against: T0077, T0067.000, T0102, T0011.003	
5	You host or fine-tune the model?	Model tampering (LLM04) Training-data poisoning (LLM04) Test against: T0018.000/.001/.003, T0020, T0031, T0076, T0115.000/.001	
6	No usage ceilings, or tools that take actions?	Unbounded consumption (LLM10) Excessive agency, see Agentic (LLM06) Test against: T0029, T0034.000/.001/.002, T0046, T0053	

Agentic app (1 of 2)

Tools, planning, memory, autonomy

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance <i>Prerequisite</i>	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber <i>Related activity</i>	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions >
1	Ingests external content or tool output?	<u>Goal hijack, direct and hidden injection (ASI01, LLM01)</u> <i>Test against: T0051.001/.002, T0093, T0094, T0099, T0110.002</i>	
2	Uses tools: read-only, or consequential actions?	<u>Tool misuse and exploitation (ASI02, LLM06)</u> <i>Test against: T0053, T0084.001/.002/.003, T0086, T0101</i>	
3	Can generate or run code / shell?	<u>Unexpected code execution (ASI05, LLM05)</u> <i>Test against: T0050, T0072, T0105, T0112.000</i>	

Agentic app (2 of 2)

Tools, planning, memory, autonomy

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance Prerequisite	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber Related activity	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions
4 Holds credentials, or acts as the user?		<u>Identity and privilege abuse (ASI03, LLM06)</u> Test against: T0012, T0055, T0083, T0091.000/.001, T0106, T0113	
5 Dynamic tools / MCP, or persistent memory?		<u>Supply-chain compromise (ASI04, LLM03)</u> <u>Memory and context poisoning (ASI06, LLM04)</u> Test against: T0010.005, T0011.002, T0110.000/.001, T0080.000/.001, T0092	
6 Multi-agent, or high autonomy on actions?		<u>Inter-agent comms, cascading failures (ASI07, ASI08)</u> <u>Over-trust, rogue agents (ASI09, ASI10, LLM09)</u> Test against: T0108, T0103, T0061 - no exact ASI07 or ASI08 technique	

Code generation (1 of 2)

Developer assistant (Claude Code, AWS Transform, other)

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance <i>Prerequisite</i>	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber <i>Related activity</i>	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions ›
1 Executes code, shell, installs packages?		Code execution (ASI05, LLM05) Sandbox escape (ASI05) Test against: T0050, T0072, T0105, T0112.000/.001	
2 Pulls dependencies?		Poisoned packages, slopsquatting (ASI04, LLM03) Supply chain (ASI04, LLM03) Test against: T0011.001, T0010.001, T0109, T0111	
3 Reads a repo or context that may be tampered?		Goal hijack via poisoned context (ASI01, LLM01) Test against: T0051.001, T0066, T0099, T0018.003	

Code generation (2 of 2)

Developer assistant (Claude Code, AWS Transform, other)

Prerequisites and related activities are owned by the cyber and governance functions and assessed through your existing governance processes. They are shown for orientation; work the questions below for the technical threat model. Answer each question yes, no or unsure: a yes or unsure carries its risks into the threat model.

AI governance Prerequisite	Registration, risk rating, Review Panel and sign-off through your AI and model governance process.	Baseline cyber Related activity	Assessed in parallel through existing cyber controls and STRIDE threat modelling. Use the organisation's risk method to prioritise the findings. Baseline questions
4 Holds repo credentials, commits or pushes?		Identity and privilege abuse (ASI03, LLM06) Test against: T0012, T0055, T0083, T0091.000	
5 Generated code trusted without review?		Overreliance (ASI09, LLM09) Insecure code shipped (LLM05) Test against: T0060, T0062, T0067.000, T0100	
6 Persistent project context or memory?		Memory poisoning (ASI06, LLM04) Test against: T0080.000/.001, T0092, T0059	

Third-party AI - mitigations

First-pass mitigations, aligned to OWASP recommended controls: review and tailor to your firm.

1 Data exposure (LLM02)
Classify data first; DLP to keep sensitive and personal data out of prompts; contractual no-training and deletion.

1 Residency and sovereignty (Gov)
Confirm which locations are approved and what transfer arrangements apply; record in your AI register.

2 Shadow AI (Gov)
Discover AI use via egress/CASB (cloud access security broker); route staff to approved tools; enforce SSO and acceptable-use.

2 Uncontrolled leakage (LLM02)
Enterprise tenant only, never personal accounts; DLP on inputs; route staff to approved tools; share least data.

3 IP and data exposure (LLM02)
Contractual no-training on data and prompts; intellectual property terms confirmed; use the enterprise plan.

3 Retention / opt-out (Gov)
Confirm retention and deletion rights; enable training opt-out; document in the DPIA and contract.

4 Hidden prompt injection (LLM01)
Treat retrieved content as untrusted; separate instructions from data; sanitise inputs and test indirect injection.

4 Over-broad access (LLM06)
Scope connectors to least privilege; per-source access; no tenant-wide grants; re-certify permissions.

5 Excessive agency (LLM06)
Grant the fewest tools and permissions; human approval for consequential actions; scope and rate-limit.

6 Supply-chain and model-change risk (LLM03)
Assess vendor security and provenance; pin and monitor model versions; plan exit and fallback.

6 Overreliance on outputs (LLM09)
Human in the loop for decisions; show sources and limitations; verify high-impact outputs.

Controls are held in the playbook for this solution type; these are the direction, not the control catalogue.

Low-code - mitigations

First-pass mitigations, aligned to OWASP recommended controls: review and tailor to your firm.

- 1 Unrestricted authoring (Gov)**
Manage the default environment; restrict maker access; approve and catalogue agents before publish.
- 1 No DLP, sprawl (Gov)**
Apply DLP to connectors and knowledge sources; inventory agents; control publishing; retire unused agents.
- 2 Over-broad access (LLM06)**
Scope connectors to least privilege; per-source access; no tenant-wide grants; re-certify permissions.
- 2 Hidden injection, DLP gaps (LLM01)**
Treat knowledge-source content as untrusted; DLP on sources; separate instructions from data; test injection.
- 3 Tool misuse (ASI02, LLM06)**
Least-privilege connectors; allow-list actions; approvals and rate limits; block risky connector combinations.
- 3 Tenant-isolation bypass, exfiltration (Baseline)**
Restrict HTTP and custom connectors; egress controls; monitor outbound; DLP on data leaving the tenant.

- 4 Identity and privilege abuse (ASI03, LLM06)**
Give each agent its own identity; least-privilege, short-lived scoped credentials; strong authN/authZ; audit actions.
- 4 No audit trail (Gov)**
Log per-agent actions to the SIEM; retain and review; ensure non-repudiation for agent actions.
- 5 Untrusted-user injection (ASI01, LLM01)**
Treat user and channel input as untrusted; filter in and out; constrain tools; approvals; test injection.
- 5 Exposure (LLM02)**
Limit knowledge sources to what the audience may see; per-channel access; redact sensitive fields.
- 6 Excessive agency, cascading actions (ASI08, LLM06)**
Least privilege and approval for consequential flows; isolate steps; circuit-breakers and rate limits.
- 6 Rogue agents (ASI10, LLM09)**
Baseline behaviour and monitor for drift; constrain scope; kill-switch; periodically review agent purpose.

Controls are held in the playbook for this solution type; these are the direction, not the control catalogue.

API integration / GenAI app - mitigations

First-pass mitigations, aligned to OWASP recommended controls: review and tailor to your firm.

- 1 Prompt injection (LLM01)**
Separate instructions from user data; filter in and out; least-privilege downstream; test adversarially.
- 1 Jailbreak (LLM01)**
Layered input and output guardrails; constrain output format; refuse-and-log; continuous red-teaming.
- 2 Poisoned index, hidden injection (LLM01, LLM08)**
Vet and sanitise ingested content; source provenance; access-control the vector store; treat retrieval as untrusted.
- 2 Sensitive data in embeddings (LLM08, LLM02)**
Exclude sensitive fields from indexing; per-tenant partitioning and access; encrypt at rest.
- 3 System-prompt and secrets leakage (LLM07)**
Keep no secrets or access logic in the prompt; enforce authorisation outside the model; assume it can leak.
- 4 Improper output handling (LLM05)**
Treat output as untrusted; context-aware encoding; parameterised queries; validate before use.

- 4 Downstream injection (LLM05)**
Context-aware encoding for HTML, bound parameters for SQL values, constrained APIs and arguments for commands; never pass raw output to interpreters.
- 5 Model tampering (LLM04)**
Sign and integrity-check model artefacts; controlled registry and access; verify on load.
- 5 Training-data poisoning (LLM04)**
Vet and track data lineage; validate and sanitise training data; anomaly detection; red-team.
- 6 Unbounded consumption (LLM10)**
Rate limits, quotas and token/timeout caps; input-size limits; spend monitoring and alerts.
- 6 Excessive agency (LLM06)**
Grant the fewest tools and permissions; human approval for consequential actions; scope and rate-limit.

Controls are held in the playbook for this solution type; these are the direction, not the control catalogue.

Agentic app - mitigations

First-pass mitigations, aligned to OWASP recommended controls: review and tailor to your firm.

- 1 Goal hijack, direct and hidden injection (ASI01, LLM01)**
Separate trusted instructions from external data; provenance-check inputs; constrain goals and tools; approvals.
- 2 Tool misuse and exploitation (ASI02, LLM06)**
Least-privilege, allow-listed tools; validate arguments; budgets and rate limits; block unsafe tool chains.
- 3 Unexpected code execution (ASI05, LLM05)**
Run code only in a sandbox with no secrets, limited resources and egress; validate and allow-list.
- 4 Identity and privilege abuse (ASI03, LLM06)**
Give each agent its own identity; least-privilege, short-lived scoped credentials; strong authN/authZ; audit actions.
- 5 Supply-chain compromise (ASI04, LLM03)**
Vet and sign tools, plugins and MCP (Model Context Protocol) servers; pin versions; verify schemas; sandbox external components.
- 5 Memory and context poisoning (ASI06, LLM04)**
Validate what enters memory; integrity and provenance checks; isolate per session; periodic audits.

- 6 Inter-agent comms, cascading failures (ASI07, ASI08)**
Authenticate, encrypt and validate agent messages; circuit-breakers and fallbacks; monitor for loops.
- 6 Over-trust, rogue agents (ASI09, ASI10, LLM09)**
Human approval for high-stakes actions; show reasoning and uncertainty; monitor drift; kill-switch.

Controls are held in the playbook for this solution type; these are the direction, not the control catalogue.

Code generation - mitigations

First-pass mitigations, aligned to OWASP recommended controls: review and tailor to your firm.

1 Code execution (ASI05, LLM05)
Execute only in an isolated sandbox; no production secrets; resource and egress limits; review before running.

1 Sandbox escape (ASI05)
Harden and patch the sandbox; drop privileges; restrict syscalls and network; monitor for escapes.

2 Poisoned packages, slopsquatting (ASI04, LLM03)
Slopsquatting is attackers publishing packages under names hallucinated by models; it need not be a typo of an existing package. Pin and verify dependencies from a trusted registry; check names before install; SBOM and scanning.

2 Supply chain (ASI04, LLM03)
SBOM, provenance and signing; pin versions; vet third-party components; scan in CI.

3 Goal hijack via poisoned context (ASI01, LLM01)
Treat repo and issue content as untrusted; separate instructions from data; review agent plans; limit auto-actions.

4 Identity and privilege abuse (ASI03, LLM06)
Distinct identity for the assistant; short-lived scoped credentials; no direct write to protected branches; audit.

5 Overreliance (ASI09, LLM09)
Human review of generated code should be required; SAST and secrets scanning; tests before merge; no auto-merge.

5 Insecure code shipped (LLM05)
SAST, dependency and secrets scanning in CI; peer review; block merge on findings.

6 Memory poisoning (ASI06, LLM04)
Validate project context; provenance and integrity checks; isolate and periodically reset; audit stored context.

Controls are held in the playbook for this solution type; these are the direction, not the control catalogue.

AI threat groups

These are the AI-specific risks a generic STRIDE checklist can miss, grouped by what they act on.

Instruction integrity

Content the system reads can carry instructions it then follows. LLM01, ASI01 · nearest STRIDE: tampering

Retrieval and memory

What it reads and remembers can be staged or poisoned, and can persist into later work. LLM08, ASI06 · tampering, disclosure

Model and data provenance

Models, training data, tools and packages can be altered upstream of you. LLM03, LLM04, ASI04 · tampering, and no single STRIDE letter

Agency and tool use

It acts rather than only answers: tools, connectors, actions, generated code. LLM06, ASI02, ASI05 · elevation of privilege

Agent identity and delegation

Whose authority it acts under, and whether the action is attributable afterwards. ASI03 · spoofing, repudiation

Disclosure through the model

Prompts, embeddings, secrets and rendered output all become leak paths. LLM02, LLM07, LLM05 · information disclosure

Output trust and human factors

People act on output that is plausible and wrong, or are steered by it. LLM09, ASI09 · no STRIDE equivalent

Scale and coordination

Consumption, cascades between agents, and drift from the original purpose. LLM10, ASI07, ASI08, ASI10 · denial of service, and beyond

ATLAS techniques by OWASP LLM Top 10 entry

ATLAS techniques that directly realise each risk. ATLAS tags every technique by platform: filtering to Generative AI and Agentic AI narrows the full matrix to those that apply here.

OWASP entry	Test against
LLM01 Prompt injection	T0018.003, T0051.000/.001/.002, T0052.000, T0054, T0064, T0066, T0068, T0070, T0071, T0082, T0085.000, T0093, T0094, T0099, T0110.002
LLM02 Sensitive information disclosure	T0012, T0024.000/.001/.002, T0025, T0036, T0037, T0048.004, T0051.001, T0052.000, T0057, T0064, T0066, T0070, T0071, T0082, T0085.000, T0093
LLM03 Supply chain	T0010.000/.001/.002/.003/.004/.005, T0011.001/.002, T0080.000/.001, T0092, T0109, T0110.000/.001, T0111, T0115.000/.001/.002
LLM04 Data and model poisoning	T0010.005, T0011.002, T0018.000/.001/.003, T0020, T0031, T0059, T0076, T0080.000/.001, T0092, T0110.000/.001, T0115.000/.001
LLM05 Improper output handling	T0011.003, T0050, T0060, T0062, T0067.000, T0072, T0077, T0100, T0102, T0105, T0112.000/.001
LLM06 Excessive agency	T0012, T0029, T0029 - ASI07 and ASI08 analogues only, T0034.000/.001/.002, T0046, T0053, T0055, T0064, T0066, T0070, T0071, T0083, T0084.001/.002/.003, T0085.000, T0086, T0091.000/.001, T0101, T0103, T0106, T0108, T0110.000/.002, T0113
LLM07 System prompt leakage	T0056, T0069.000/.001/.002, T0084.000
LLM08 Vector and embedding weaknesses	T0064, T0066, T0070, T0071, T0082, T0085.000
LLM09 Misinformation	T0010.000/.001/.002/.003/.004/.005, T0029 - ASI07 and ASI08 analogues only, T0034.002, T0060, T0061 - no exact ASI07 or ASI08 technique, T0062, T0067.000, T0100, T0103, T0108, T0109, T0111, T0115.000/.001/.002
LLM10 Unbounded consumption	T0029, T0034.000/.001/.002, T0046, T0053

Risk labels on the question pages are scenario names: match them to the entries here by the code. Look up technique IDs at atlas.mitre.org, filtering platform to Generative AI and Agentic AI. Techniques cited against Gov and Baseline risks belong with the governance and cyber processes, not in these tables.

ATLAS techniques by OWASP Agentic Top 10 entry

Two entries have no direct technique, which is a real gap in the catalogue rather than an omission here.

OWASP entry	Test against
ASI01 Agent goal hijack	T0018.003, T0051.001/.002, T0052.000, T0066, T0093, T0094, T0099, T0110.002
ASI02 Tool misuse and exploitation	T0053, T0084.001/.002/.003, T0086, T0101, T0110.000/.002
ASI03 Identity and privilege abuse	T0012, T0055, T0083, T0091.000/.001, T0106, T0113
ASI04 Agentic supply chain	T0010.001/.005, T0011.001/.002, T0080.000/.001, T0092, T0109, T0110.000/.001, T0111, T0115.001
ASI05 Unexpected code execution	T0050, T0072, T0105, T0112.000/.001
ASI06 Memory and context poisoning	T0010.005, T0011.002, T0059, T0080.000/.001, T0092, T0110.000/.001
ASI07 Insecure inter-agent communication	T0061 - no exact ASI07 or ASI08 technique, T0103, T0108
ASI08 Cascading failures	T0029 - ASI07 and ASI08 analogues only, T0034.002, T0061 - no exact ASI07 or ASI08 technique, T0103, T0108
ASI09 Human-agent trust exploitation	T0060, T0061 - no exact ASI07 or ASI08 technique, T0062, T0067.000, T0100, T0103, T0108
ASI10 Rogue agents	T0029 - ASI07 and ASI08 analogues only, T0034.002, T0061 - no exact ASI07 or ASI08 technique, T0103, T0108

Risk labels on the question pages are scenario names: match them to the entries here by the code. Look up technique IDs at atlas.mitre.org, filtering platform to Generative AI and Agentic AI. Techniques cited against Gov and Baseline risks belong with the governance and cyber processes, not in these tables.

Frameworks behind the navigator

[Index ›](#)

OWASP Top 10 for LLM Applications (2025)

Prompt injection, sensitive information disclosure, supply chain, data and model poisoning, improper output handling, excessive agency, system-prompt leakage, vector and embedding weaknesses, misinformation, unbounded consumption.

OWASP Top 10 for Agentic Applications (ASI, 2026)

Agent goal hijack, tool misuse and exploitation, agent identity and privilege abuse, agentic supply-chain compromise, unexpected code execution, memory and context poisoning, insecure inter-agent communication, cascading agent failures, human-agent trust exploitation, rogue agents.

MITRE ATLAS (content 2026.07)

Adversary behaviour against AI systems, graded Feasible, Demonstrated and Realized. Each question carries a Test against line of technique identifiers; the appendix sorts them into families.

Companions. The full method, worked example and MAESTRO validation are in the AI Threat Modelling Guide (v2.3) and its Worked Example Workbook, held in the same folder as this navigator. Assurances such as enterprise plans, signatures and logging are controls with a defined scope; none alone establishes no-training, safe behaviour or non-repudiation.